

SUPSI

Rilevamento dati personali in documenti non strutturati aziendali

Studente/i

Algisi Gabriele

Relatore

Gay Mario

Correlatore

Consoli Angelo

Committente

Gay Mario

Corso di laurea

Ingegneria Informatica

Modulo

C11303

Anno

2025-2026

Data

17 giugno 2026

Indice

1	Introduzione	1
1.1	Riassunto / Abstract	1
1.2	Progetto assegnato	1
1.3	Contesto	2
1.4	Motivazione	3
1.5	Obiettivi del progetto	3
2	Analisi dei requisiti	5
2.1	Requisiti funzionali	5
2.1.1	Acquisizione dell'input	5
2.1.2	Estrazione del testo	5
2.1.3	Rilevamento delle PII	5
2.1.4	Aggregazione delle PII frammentate DA VALUTARE	6
2.1.5	Costruzione di una knowledge base delle entità DA VALUTARE	6
2.1.6	Ingestione del/i ROPA	6
2.1.7	Confronto knowledge (o risultati di analisi) con ROPA	6
2.1.8	Rilevamento delle anomalie di conformità	7
2.1.9	Generazione report per DPO	7
2.2	Requisiti normativi	7
2.2.1	Conformità ai principi di limitazione delle finalità e della conservazione	7
2.2.2	Riferimento al registro delle attività di trattamento come fonte normativa	7
2.2.3	Copertura delle categorie di dati degni di particolare attenzione	8
2.2.4	Posizionamento rispetto all'art.32(1)(d) GDPR	8
2.2.5	Esclusione delle basi giuridiche dal perimetro di analisi automatica	8
2.3	Requisiti operativi	8
2.3.1	Elaborazione locale dei dati	8
2.3.2	Vincolo sui modelli AI impiegabili	8
2.3.3	Facilità installazione e aggiornamento	8
2.3.4	Estensibilità delle categorie e detectors	8
2.3.5	Minimizzazione dei dati trattati dal sistema stesso	9

2.4	Requisiti di qualità	9
2.4.1	Prestazioni su larga scala	9
2.4.2	Precisione del rilevamento	9
2.4.3	Tracciabilità delle anomalie	9
2.5	Requisiti di interfaccia	9
2.5.1	da definire	9
3	Stato dell'arte	11
3.1	Definizione e inquadramento del problema	11
3.2	Approcci tecnici di PII detection	11
3.2.1	Recognition rule-based	11
3.2.2	Recognition con NLP - NER	12
3.2.3	Recognition con AI generativa	12
3.2.4	Limitazioni nella soluzione	12
3.2.5	Soluzioni ibride	12
3.3	Compliance checking automatizzato	12
3.4	Strumenti di supporto al document processing	12
3.4.1	Docling	12
3.4.2	Altro...	13
3.5	Panoramica dei sistemi esistenti	13
3.5.1	Sistemi open-source	13
3.5.2	Sistemi commerciali	13
3.6	Sintesi del gap e posizionamento del progetto	13
4	Analisi dei rischi	15
5	Architettura del sistema	17
6	Implementazione	19
7	Test e validazione	21
8	Risultati e discussione	23
9	Sviluppi futuri	25
10	Studi effettuati	27

Capitolo 1

Introduzione

1.1 Riassunto / Abstract

Qui ci sarà l'abstract...

1.2 Progetto assegnato

Le aziende e le organizzazioni soggette alla nLPD (nuova Legge federale sulla protezione dei dati) sono tenute a sapere dove si trovano i dati personali che trattano, a quale trattamento riportato del registro dei trattamenti sono riconducibili e se sono ancora entro i termini di conservazione dichiarati nel registro. Nella pratica però, gran parte di questi dati è dispersa in documenti non strutturati — ad esempio PDF, Word, Excel, scansioni — senza che l'organizzazione ne abbia visibilità sistematica.

Gli strumenti disponibili sul mercato, sia quelli più abordabili (es. PII Crawler, PII Tools) sia quelli enterprise (es. BigID, Varonis), sono progettati per garantire la conformità con normative europee (GDPR) o statunitensi (es.: CCPA) e non necessariamente gestiscono le categorie di dati specifiche della nLPD svizzera senza configurazioni e validazioni specifiche. Oltre a ciò, solo alcuni prodotti enterprise più avanzati integrano il registro dei trattamenti come input normativo configurabile. Di conseguenza la verifica del superamento del periodo di retention è spesso possibile solo tramite una categorizzazione molto precisa all'origine.

Il progetto propone lo sviluppo di un sistema in grado di evidenziare il divario tra le attività di trattamento dichiarate nel registro e l'effettiva gestione dei documenti aziendali, anche utilizzando tecniche NLP e AI. Per ciascun documento analizzato, il sistema deve identificare eventuali dati personali presenti (Personally Identifiable Information, PII), associare il documento alla corrispondente attività di trattamento combinando diversi indicatori (es. posizione nel file system, contenuto, PII identificati) e verificare la conformità al periodo di conservazione dichiarato nel registro. I documenti che hanno superato il loro periodo di conservazione

e le PII [1] che non possono essere collegate ad alcuna operazione di trattamento registrata devono essere segnalati come anomalie.

1.3 Contesto

La protezione dei dati personali costituisce oggi uno dei nodi centrali della governance organizzativa, tanto sul piano giuridico quanto su quello operativo. In Europa, il regolamento (UE) 2016/679 (GDPR) [2] ha introdotto un corpus di obblighi sostanziali per i titolari del trattamento, tra cui il principio di limitazione della conservazione sancito dall'art. 5(1)(e), secondo cui i dati personali devono essere conservati "in una forma che consenta l'identificazione degli interessati per un arco di tempo non superiore al conseguimento delle finalità per le quali sono trattati". In Svizzera, la nuova Legge federale sulla protezione dei dati (nLPD, RS 235.1, in vigore dal 1° settembre 2023) ha recepito principi analoghi: l'art 6(4) dispone che "i dati personali sono distrutti o resi anonimi appena non sono più necessari per lo scopo del trattamento", stabilendo un legame diretto tra la finalità dichiarata e il ciclo di vita del dato. Entrambe le normative impongono inoltre la tenuta di un registro delle attività di trattamento (ROPA, Record of Processing Activities). Il GDPR, all'art. 30(1)(f), richiede che il registro contenga, "ove possibile, i termini ultimi previsti per la cancellazione delle diverse categorie di dati"; la nLPD [3], all'art. 12(2)(e), prevede analogamente l'indicazione della durata di conservazione dei dati personali o dei criteri per determinarne la durata. Il ROPA costituisce dunque il documento normativo di riferimento per qualsiasi verifica di conformità: è in esso che l'organizzazione dichiara cosa tratta, perché, con quale base giuridica e per quanto tempo. I due ordinamenti divergono tuttavia su un punto strutturalmente rilevante per qualsiasi sistema di verifica automatica. Il GDPR enumera positivamente le basi giuridiche lecite all'art. 6(1), subordinando la liceità del trattamento alla sussistenza di almeno una di esse. La nLPD adotta invece un approccio invertito: il trattamento è lecito per default in quanto esercizio della libertà d'azione dei privati, ma diventa illecito se lede ingiustificatamente la personalità dell'interessato ai sensi dell'art. 30. La giustificazione può provenire dal consenso, da un interesse preponderante o dalla legge, secondo il catalogo dell'art. 31. Questa differenza strutturale impone che un sistema di analisi della conformità tenga conto del framework giuridico applicabile, poiché il criterio con cui si valuta l'esistenza di una base legittima non è identico nei due contesti. Nella pratica organizzativa, la conformità dichiarata nel registro tende a divergere dalla situazione reale dei dati. Gran parte dell'informazione trattata da un'organizzazione è incorporata in documenti non strutturati (file PDF, Word, Excel, messaggi di posta elettronica. . .) distribuiti su file system locali, server condivisi e servizi cloud. Questi documenti non recano metadati normalizzati che consentono di associarli automaticamente a un'attività di trattamento specifica, né di verificarne la conformità al periodo di retention dichiarato. Il risultato è un divario strutturale tra ciò che il registro descrive e ciò che esiste effettivamente nei sistemi informativi dell'organizzazio-

ne. Questo divario assume rilevanza giuridica diretta. Il GDPR all'art. 32(1)(d) qualifica come misura di sicurezza obbligatoria una procedura per testare, verificare e valutare regolarmente l'efficacia delle misure tecniche e organizzative al fine di garantire la sicurezza del trattamento. La nLPD, pur con formulazione più sintetica, impone all'art. 8(1) che il titolare e il responsabile del trattamento garantiscano, mediante appropriati provvedimenti tecnici e organizzativi, che la sicurezza dei dati personali sia adeguata al rischio. Un sistema in grado di rilevare automaticamente i dati personali presenti nei documenti aziendali e di verificarne la coerenza con il registro può essere inteso come implementazione tecnica di quest'obbligo.

1.4 Motivazione

Qui va la motivazione...

1.5 Obiettivi del progetto

Per ora solamente obiettivi del progetto, valutare se riformulare

Il progetto intende produrre un sistema che renda visibile lo scarto tra le attività di trattamento dichiarate nel registro e la gestione effettiva dei dati nei documenti aziendali. In pratica, il prototipo dovrà:

- rilevare le categorie di dati personali presenti in documenti non strutturati, sulla base delle categorie canoniche della nLPD e di quelle dichiarate nel registro dei trattamenti;
- associare i documenti al trattamento corrispondente combinando più segnali;
- verificare la conformità ai periodi di retention dichiarati nel registro;
- segnalare categorie di dati personali non dichiarate nel registro e trattamenti non censiti;
- produrre un report leggibile dal Data Protection Officer dell'organizzazione.

Capitolo 2

Analisi dei requisiti

La struttura di questo capitolo si ispira allo standard ISO/IEC/IEEE 29148:2018 - Systems and Software Engineering - Life cycle processes- Requirements engineering [CITAZIONE: ISO/IEC/IEEE 29148:2018] DA CAPIRE CITAZIONE.

2.1 Requisiti funzionali

2.1.1 Acquisizione dell'input

Il sistema deve poter analizzare come input un insieme di file selezionati, una cartella, oppure un intero file system. L'acquisizione deve avvenire senza presupporre una struttura predefinita dell'albero di directory, supportando l'elaborazione ricorsiva di sottocartelle.

L'utente deve poter specificare percorsi multipli e/o pattern di esclusione (es. cartelle di sistema, file temporanei etc...) per limitare la scansione ai soli percorsi rilevanti.

2.1.2 Estrazione del testo

Il sistema deve estrarre il contenuto testuale dai documenti non strutturati (PDF, Word, Excel, immagini scansionate) indipendente dal formato di partenza.

L'estrazione deve preservare, dove possibile, i metadati strutturali del documento (es. tabelle, intestazioni, numeri di pagina) necessari a contestualizzare le PII rilevate e a tracciarne la posizione nel report finale (cfr. [requisito RO7 - RACCIABILITÀ]).

2.1.3 Rilevamento delle PII

Il sistema deve identificare le occorrenze di dati personali nel testo estratto, tramite una combinazione di meccanismi (regex, ML, NLP) la cui composizione esatta è oggetto di definizione architetturale.

Il rilevamento deve coprire, come minimo, le categorie di dati personali rilevanti ai sensi della nLPD e del GDPR (es. dati identificativi, dati di contatto, identificatori numerici nazionali, dati relativi alla salute, dati degni di particolare protezione secondo l'art. 5 lett. c nLPD CITA e l'art. 9 GDPR CITA).

2.1.4 Aggregazione delle PII frammentate | DA VALUTARE

Il sistema deve essere in grado di ricondurre frammenti di informazione dispersi all'interno di uno o più documenti a un'unica entità coerente (es. nome, identificativo, indirizzo di una stessa persona riportati in punti diversi del testo o in documenti diversi).

L'aggregazione deve basarsi su criteri verificabili (es. co-occorrenza, similarità semantica, identificatori univoci condivisi...) e deve essere documentata nel report ai fini di tracciabilità.

2.1.5 Costruzione di una knowledge base delle entità | DA VALUTARE

A partire dalle PII estratte, il sistema deve costruire una rappresentazione strutturata delle entità rilevate nel sistema documentale (tramite NER), che costituisce la base per il confronto con il ROPA.

La rappresentazione deve associare a ciascuna entità: le categorie di PII rilevate, i documenti di provenienza, e i riferimenti di posizione necessari per l'auditing.

2.1.6 Ingestione del/i ROPA

Il sistema deve accettare uno o più registri delle attività di trattamenti (ROPA) in formato strutturato come riferimento normativo per il confronto.

Il formato di ingestione deve includere, per ogni attività di trattamento: categorie di dati personali previste, finalità del trattamento, periodo di conservazione dichiarato (o criteri per la sua determinazione), e categorie di interessati.

2.1.7 Confronto knowledge (o risultati di analisi) con ROPA

Il sistema deve confrontare le entità e le categorie di dati personali effettivamente rilevate nei documenti con quanto dichiarata nel/i ROPA, verificando l'accuratezza e la coerenza tra dati trovati e dati dichiarati.

Il confronto deve produrre, per ciascuna entità/documento analizzato, un'associazione (anche parziale o nulla) con una o più attività di trattamento del ROPA, secondo criteri ed euristiche definiti in fase di progettazione architettuale.

2.1.8 Rilevamento delle anomalie di conformità

Il sistema deve identificare e classificare, sulla base del confronto di 2.1.7, le seguenti tipologie di anomalie:

- categorie di PII rilevate ma non dichiarate nel ROPA per l'attività di trattamento associata;
- dati personali privi di una base giuridica/attività di trattamento associabile ("PII orfane");
- violazioni dei periodi di conservazione dichiarati nel ROPA (documenti contenenti PII oltre il termine di retention dichiarato).

Ogni anomalia rilevata deve essere classificata secondo una tipologia predefinita e associata a un livello di gravità/priorità.

2.1.9 Generazione report per DPO

Il sistema deve produrre, come output finale, un report strutturato e leggibile destinato al Data Protection Officer (DPO), contenente le anomalie di conformità rilevate.

Il report deve includere, per ciascuna anomalia: tipologia, documento/i coinvolti, attività di trattamento di riferimento (se presente) e la motivazione/base del rilevamento.

2.2 Requisiti normativi

2.2.1 Conformità ai principi di limitazione delle finalità e della conservazione

Il sistema deve supportare la verifica di conformità ai principi di limitazione della finalità (art. 5(1)(b) GDPR; art. 6 cpv. 3 nLPD) e di limitazione della conservazione (art. 5(1)(e) GDPR; art. 6 cpv. 4 nLPD) [CAPIRE COME CITARE CON LINK E ZOTERO], confrontando i dati personali rilevati con le finalità e i periodi di conservazione dichiarati nel ROPA.

2.2.2 Riferimento al registro delle attività di trattamento come fonte normativa

Il sistema deve trattare il/i ROPA forniti in input come riferimento normativo autoritativo, conformemente a quanto previsto dall'art. 30 GDPR e dall'art. 12 nLPD in merito al contenuto minimo del registro (categorie di interessati, categorie di dati personali, finalità, durata di conservazione, categorie di destinatari).

2.2.3 Copertura delle categorie di dati degni di particolare attenzione

Il sistema deve essere in grado di riconoscere le categorie di dati personali degni di particolare protezione secondo l'art. 5 lett.c nLPD e le categorie particolari di dati personali secondo l'art. 9(1) GDPR, segnalandone la presenza con priorità elevata nel report delle anomalie, in considerazione del regime di consenso espresso richiesto (art. 6 cpv.7 lett. a nLPD; art. 9(2) GDPR).

2.2.4 Posizionamento rispetto all'art.32(1)(d) GDPR

proc. testare misure tecniche adottate per proteggere i dati

Il sistema deve costituire, nel suo funzionamento periodico, un'implementazione tecnica della procedura di test, verifica e valutazione regolare dell'efficacia delle misure tecniche e organizzative di cui all'art. 32(1)(d) GDPR e all'art. 8 nLPD, senza tuttavia implementare funzioni di anonimizzazione o di gestione degli incidenti, che restano fuori dal perimetro del progetto.

2.2.5 Esclusione delle basi giuridiche dal perimetro di analisi automatica

Il sistema non deve determinare autonomamente la base giurifica applicabile a un trattamento (art. 6 GDPR; art. 30-31 nLPD); tale valutazione resta di competenza del DPO. Il sistema si limita a segnalare l'assenza di un'attività di trattamento associabile ("PII orfane") come elemento informativo a supporto della valutazione umana.

2.3 Requisiti operativi

2.3.1 Elaborazione locale dei dati

Ogni dato analizzato deve rimanere nell'infrastruttura in cui si trova inizialmente. Essendo che si trattano dati particolarmente pericolosi per la libertà degli individui (citazione...), usufruire di servizi terzi per analizzare o elaborare i dati è fuori discussione.

2.3.2 Vincolo sui modelli AI impiegabili

TODO: testo da scrivere.

2.3.3 Facilità installazione e aggiornamento

TODO: testo da scrivere.

2.3.4 Estensibilità delle categorie e detectors

TODO: testo da scrivere.

2.3.5 Minimizzazione dei dati trattati dal sistema stesso

TODO: testo da scrivere.

2.4 Requisiti di qualità

TODO: testo da scrivere.

2.4.1 Prestazioni su larga scala

TODO: testo da scrivere.

2.4.2 Precisione del rilevamento

TODO: testo da scrivere.

2.4.3 Tracciabilità delle anomalie

TODO: testo da scrivere.

2.5 Requisiti di interfaccia

2.5.1 da definire

TODO: testo da scrivere.

Capitolo 3

Stato dell'arte

Scaffolding precoce della struttura che avrà questo capitolo.

3.1 Definizione e inquadramento del problema

da capire cosa mettere in questa sezione, per non essere ripetitivo con quella del contesto

3.2 Approcci tecnici di PII detection

Per rilevare le PII, esistono più metodi e strategie, tutte ampiamente discusse in studi accademici. Ognuna di queste ha dei punti di forza e di debolezza, infatti esiste una area di problemi dove ogni singola opzione diventa la migliore, riducendo o addirittura annullando gli effetti negativi.

Le soluzioni in questione sono:

3.2.1 Recognition rule-based

Approccio più semplice e rule-based. La detection delle PII è solamente affidata a regole di pattern-matching e meccanismi simili. Come si può già intuire, questo approccio, per alcune categorie di dati sensibili, è particolarmente efficace: la massima performance si ottiene quando si trattano dati strettamente formattati in determinati modi (IBAN, AVS, codice fiscale etc...). **[CITA QUI STUDI SU REGEX]** Questo approccio tuttavia, ha dei problemi seri che non possono essere trascurati: [da capire se mettere lista oppure lasciare testo] categorie nettamente più difficili da trovare (nomi propri per esempio, in quanto si baserebbero su regole facilmente mal-interpretabili e con un alto numero di falsi positivi (es. lettera maiuscola) [IDEA: libreria per checkare se una parola sia nel dizionario italiano/inglese. SE NO, ALLORA NOME PROPRIO]) Vantaggio: più veloce in assoluto tra tutte le soluzioni.

3.2.2 Recognition con NLP - NER

3.2.3 Recognition con AI generativa

Ultima soluzione "pura" è l'utilizzo di LLM con AI generativa per l'individuazione di PII. Questo approccio, fortemente documentato e discusso, è senza dubbio il migliore per quanto riguarda solamente le performance. Infatti, seppur riesce ad avere un F1-score e una recall senza precedenti, ha un costo computazionale e di risorse senza precedenti, spesso ingestibile per la maggior parte delle macchine. Gli unici modi per rendere accettabili tempi di esecuzione è di down-scalare i modelli utilizzati, riducendo contesto e "intelligenza" dello stesso. Seppur di aiuto, più si scende con la dimensione e il peso dei modelli, più il vantaggio di usare gli LLM si assottiglia, fino ad azzerarsi rispetto all'uso dell'NLP.

Tuttavia, gli LLM hanno un vantaggio unico per quanto riguarda un aspetto fondamentale nel nostro problema: la presenza nativa del 'contesto'. Infatti gli LLM sono [molto simili al cervello umano per il ragionamento, quindi comprendono un testo, oltre a leggerlo | ',:]

3.2.4 Limitazioni nella soluzione

Come visto nella sezione precedente, la soluzione parzialmente migliore sembrerebbe essere la detection con NLP. Questo perché riesce ad avere una percentuale di matching particolarmente alta, senza aver bisogno della quantità ingestibilmente alta di risorse dell'AI generativa.

Tuttavia, questa soluzione diventa praticamente insignificante se teniamo in considerazione l'aspetto dello "**Zero training**". Infatti, da requisiti [LINK AI REQUISITI], il nostro sistema di detection deve essere ready-to-use non appena installato, garantendo una buona percentuale di detection senza aver bisogno dei dati su cui sta lavorando. Le metodologie NLP - NER hanno alla base proprio la knowledge dei dati che si stanno analizzando.

3.2.5 Soluzioni ibride

3.3 Compliance checking automatizzato

Proto

3.4 Strumenti di supporto al document processing

Sezione con strumenti considerati per trasformare file non strutturati in formati facilmente leggibili da regex o, più importante, AI (NLP, generativa etc...)

3.4.1 Docling

Spiegone di Docling

3.4.2 Altro...

Spiegno di altre tecnologie (che ora non ricordo)

3.5 Panoramica dei sistemi esistenti

3.5.1 Sistemi open-source

- **Microsoft Presidio:**
- **GLiNER:**

3.5.2 Sistemi commerciali

- **Varonis:**
- **BigID:**
- **PII Tools:**

3.6 Sintesi del gap e posizionamento del progetto

da inserire tabella riassuntiva (o paragrafo comparativo) che fa capire cosa "fanno gli altri" e "cosa manca".

Capitolo 4

Analisi dei rischi

Capitolo 5

Architettura del sistema

Capitolo 6

Implementazione

Capitolo 7

Test e validazione

Capitolo 8

Risultati e discussione

Capitolo 9

Sviluppi futuri

Capitolo 10

Studi effettuati

Sezione specifica per incorporare studi effettuati che non sono strettamente legati alla realizzazione dell'applicazione in questione, ma che dal punto di vista accademico sono comunque interessanti.

Elenco delle figure

Elenco delle tabelle

Bibliografia

- [1] Shirley Radack. Protecting Personally Identifiable Information. page 59.
- [2] Parlamento europeo e Consiglio dell'Unione europea. Regolamento (ue) 2016/679.
- [3] RS 235.1 - Legge federale del 25 settembre 2020 sulla protezione dei dati (LPD) | Fedlex.